

Arkime PCAP 脅威ハンティング チートシート

フルパケットキャプチャ (FPC) によるペイロード深掘り解析リファレンス

本ドキュメントは、オープンソースのパケットキャプチャ&検索ツール「Arkime (旧Moloch)」を利用し、サイバーキルチェーンの各フェーズにおける実際のペイロード（通信の中身）を解析するための検索構文（SPI Query）をまとめたものです。

★ SIEMにはない！Arkime（PCAP解析）ならではの必須調査事項

- **ファイルの抽出 (File Carving):** SIEMでは「.exeがダウンロードされた」というログしか残りませんが、Arkimeならセッションの [Download PCAP] や [Export] 機能から、ネットワーク上を流れたマルウェア本体（PEファイルやマクロ付きPDF等）をそのまま抽出し、サンドボックスやリバースエンジニアリングに回すことが可能です。
- **リバースシェルの平文コマンド追跡:** Netcat等を利用したDouble NCリバースシェル通信が確立された場合、SIEMでは「非標準ポートでの通信」としてしか見えません。Arkimeならパケットのペイロードを直接確認できるため、攻撃者が打ち込んだコマンドや、権限昇格（system32の奪取など）の生々しい出力をASCII/HEX形式で完全に読むことができます。
- **ゼロデイエクスプロイトの生データ検証:** 攻撃コード（例: C#でコンパイルされた悪性ペイロードの痕跡や、Log4Shellのような特定文字列）が通信のどの部分（HTTPヘッダー、POSTボディの中身など）に埋め込まれていたか、生バイト単位で正規表現検索（`payload.utf8 == /regex/`）が可能です。

1. 偵察 (Reconnaissance)

1-1. Webサーバーへのスキャンとエクスプロイト探索の生ペイロード確認

404エラーをトリガーに、実際にどのようなURIがリクエストされていたか、User-Agentに不審なツール名が含まれていないかを確認します。

Arkime
HTTPスキャン

```
# HTTP 404エラーを返し、かつ特定の拡張子 (.env, .php, .gitなど) を探している通信
```

```
protocols == http && http.statuscode == 404 && http.uri == [ "*.env", "*.git", "*phpmyadmin*" ]
```

3. 配送 (Delivery)

3-1. マジックバイト (File Magic) による実行可能ファイルの検知

拡張子が偽装されていても、ファイルヘッダ（マジックバイト）からダウンロードされたファイルの種類を特定します。

Arkime

ファイルダウンロード

```
# HTTPまたはSMB経由でWindows実行可能ファイル(MZヘッダ)が転送されたセッション
```

```
file.magic == "MZ" && (protocols == http || protocols == smb)  
※発見後、対象セッションを開き「Download PCAP」からファイルを抽出してハッシュ値  
を算出。
```

4. エクスプロイト (Exploitation)

4-1. 生ペイロード内の攻撃シグネチャ検索 (Log4Shell / OGNL Injection等)

WAFをすり抜けた攻撃に対して、PCAPの生データから特定の文字列や難読化されたコードを直接検索します。

Arkime

ペイロード検索

```
# HTTPヘッダーまたはボディに "jndi:ldap" やコマンドインジェクションの兆候を含  
む通信
```

```
payload.utf8 == "*jndi:*" || payload.utf8 == "*wget *" ||  
payload.utf8 == "*curl *" || http.uri.tokens == "cmd"
```

6. 遠隔操作 (Command and Control - C2)

6-1. 非標準ポートでの平文/暗号化シェルの特定

80番や443番以外のポートで、大量のパケットがやり取りされているセッションを特定します。

Arkime

リバースシェル

```
# Web(80/443), DNS(53)以外のTCP通信で、ある程度パケット数（対話）があるもの  
を抽出
```

```
protocols == tcp && port != 80 && port != 443 && port != 53  
&& packets >= 20
```

```
※セッションを開き、ASCII表示で "Microsoft Windows" や "C:\\" などの文字列が  
見えれば平文シェル確定。
```

6-2. DNSトンネリングの通信量の視覚化

DNSクエリの中にC2の命令や持ち出しデータが埋め込まれている事象をパケットサイズで検知します。

Arkime

DNS異常

```
# TXTレコードや巨大なクエリを持つDNS通信
```

```
protocols == dns && (dns.qt == "TXT" || bytes > 5000)
```

7. 目的の実行 (Actions on Objectives)

7-1. 機密データの持ち出し (Exfiltration) と中身の確認

外部への大量のデータ送信を検知し、暗号化されていない場合は**「何が持ち出されたか」**を直接読み取ります。

Arkime

大容量送信

内部から外部IPへ、50MB以上のデータが送信されたセッション

```
bytes.dst > 500000000 && ip.src == 10.0.0.0/8 && ip.dst !=  
10.0.0.0/8
```

※FTPやHTTPで送信された場合、ペイロードビューで「パスワードリスト」や「ソースコード」等が含まれていないか確認。